



AURIGA SECURITY · OWASP TAIWAN

你聽過跟沒聽過的 AI 鬼故事

AI Ghost Stories — the ones you've heard of, and the ones you haven't

A technical field guide to real AI security incidents, 2025–2026 — attack chains · root cause · IOCs · OWASP LLM Top 10 & MITRE ATLAS

18 deep dives + lightning rounds · **HEARD OF** vs **LESSER-KNOWN** · rigor-flagged: PoC / in-the-wild / disputed



How to read these ghost stories

Every incident is real and sourced. Each slide follows the same anatomy so you can compare hauntings quickly.



THE SETUP

The system, the trust it assumes, and the way in.



THE HAUNTING

The attack chain — how the injection is delivered and how data or control escapes.



ROOT CAUSE

The underlying design flaw, in one line.



IOCs / MAPPING

Indicators, plus OWASP LLM Top 10 (2025) & MITRE ATLAS.

The two tags that name the talk

HEARD OF

你聽過 — famous cases, retold with the technical detail usually left out.

LESSER-KNOWN

你沒聽過 — obscure but verifiable hauntings your peers probably missed.

A note on rigor — this space runs on hype

IN THE WILD = observed in real operations. **PoC** = responsibly disclosed / research prototype, never deployed. **DISPUTED** = a claim outside sources contest.

The anatomy of an AI haunting

Nearly every enterprise-AI exploit in this deck is the same three-move séance. Learn it once; you'll see it everywhere.



1 · INJECT

Indirect prompt injection arrives through a channel the user trusts — an email, a calendar invite, a CRM lead, a PR description, a Reddit comment, a support ticket.



2 · COLLECT

The model can't separate data from instructions, so it obeys — reaching into privileged scope (your inbox, private repos, CRM, connected drives).



3 · EXFIL

Stolen data leaves through the vendor's OWN allow-list — a Teams proxy, an expired CSP domain, Azure Blob, GitHub's Camo proxy, api.anthropic.com, Hugging Face.

The uncomfortable through-line

“Allow-listed” is not “aligned.” The recurring reason exfiltration works is that defenses trust first-party domains and rendered content. The workhorse channel is Markdown-image auto-rendering with data in the URL — which is why vendor fix after vendor fix simply *disables image rendering*. The frontier (ShadowLeak) skips the browser entirely and exfiltrates *server-side*, leaving no trace at all.

Map of the haunted houses

Five rooms. Eighteen deep-dive hauntings, plus two lightning rounds and an autopsy.



ACT I

The Zero-Click Hauntings

[EchoLeak](#) · [ForcedLeak](#) · [ShadowLeak](#) · [CamoLeak](#)



ACT II

Possessed Browsers & Rooms

[The Comet & your Gmail](#) · [Invitation Is All You Need](#) · [The haunted omnibar](#)



ACT III

The Developer's Nightmares

[Amazon Q wiper](#) · [Replit deletes prod](#) · [Cursor CurXecute](#) · [Nx s1ngularity](#)



ACT IV

The Poisoned Well

[nullifAI](#) · [Slopsquatting](#) · [postmark-mcp](#) · [LiteLLM / TeamPCP](#)



ACT V

When the Ghost Fights Back

[LAMEHUG](#) · [PromptLock myth](#) · [GTG-1002](#) · [The \\$25M deepfake](#)



ACT I

The Zero-Click Hauntings

Enterprise copilots that leak your data without a single click

• EchoLeak • ForcedLeak • ShadowLeak • CamoLeak

EchoLeak — Zero-Click Copilot Exfiltration

HEARD OF

CVE-2025-32711

PoC

0-CLICK

Microsoft 365 Copilot · CVE-2025-32711 · disclosed Jun 2025 · Aim Labs

THE SETUP

M365 Copilot answers from your email, Teams, SharePoint & files via RAG. The attacker only needs to send you one email — you never open it.

⚡ THE HAUNTING — attack chain

- 1 Attacker emails the victim; the injection is phrased as instructions to the human, dodging Microsoft's XPIA prompt-injection classifier.
- 2 Later the user asks Copilot anything — RAG pulls the malicious email into the trusted context ('LLM Scope Violation').
- 3 Copilot follows the hidden instructions, gathers sensitive context, and encodes it into a reference-style Markdown image URL.
- 4 That URL rides a Teams/SharePoint proxy already on Copilot's CSP allow-list; the client auto-fetches it — no click, data gone.

⚠️ ROOT CAUSE

No trust boundary between untrusted retrieved content and privileged data; redaction missed reference-style Markdown; the CSP trusted first-party proxy domains.

IMPACT

0-click

Full Copilot scope exfiltrable (mail, Teams, OneDrive, SharePoint). Patched server-side; no in-the-wild use. CVSS disputed: MS 9.3 vs NVD 7.5.

📡 IOCs / INDICATORS

- > Reference-style Markdown img / links
- > Outbound to Teams/SharePoint proxy on CSP
- > CWE-74 (Injection)

🎯 FRAMEWORK MAPPING

OWASP LLM01 · LLM02 · LLM08
ATLAS AML.T0051.001 · T0057



THE LESSON You did nothing — didn't open the mail, didn't click — and SharePoint still walked out the door.

ForcedLeak — the \$5 CRM Haunting

LESSER-KNOWN

CVSS 9.4

PoC

Salesforce Agentforce (Web-to-Lead) · disclosed Sep 2025 · Noma Labs · no public CVE

THE SETUP

Agentforce lets an employee ask an AI to process inbound sales leads. Anyone on the public web can submit a lead.

⚡ THE HAUNTING — attack chain

- 1 Attacker submits a Web-to-Lead form; payload hidden in the 42,000-char Description field — the only field big enough.
- 2 An employee asks Agentforce to 'process the lead' — a stored / second-order injection fires.
- 3 The agent queries CRM data and embeds it into an URL, URL-encoding the loot.
- 4 The image domain was on Salesforce's CSP allow-list but had EXPIRED — Noma re-bought it for \$5 and logged the data.

⚠️ ROOT CAUSE

No data/instruction boundary; unsanitized lead data; a stale CSP allow-list containing an expired, re-registrable domain.

IMPACT

\$5

An expired, allow-listed domain re-bought for \$5 → CRM exfiltration. Salesforce shipped Trusted-URL enforcement. Proof-of-concept.

📡 IOCs / INDICATORS

- > Exfil domain my-salesforce-cms.com
- > tags + %20-encoded data in leads
- > Instruction text in the Description field

🎯 FRAMEWORK MAPPING

OWASP LLM01 · LLM02 · LLM06
ATLAS AML.T0051.001 · T0057



THE LESSON Your allow-list is only as trustworthy as its most expired domain.

ShadowLeak — Exfil From Inside the Cloud

LESSER-KNOWN

PoC

SERVER-SIDE

ChatGPT Deep Research (connectors) · disclosed Sep 2025 · Radware · fixed Aug 2025

THE SETUP

ChatGPT's Deep Research agent autonomously reads your connected Gmail/Drive and browses the web — all on OpenAI's servers.

⚡ THE HAUNTING — attack chain

- 1 Attacker emails hidden instructions (tiny / white font) into the victim's connected inbox.
- 2 Victim asks Deep Research to 'summarize my inbox'; the agent ingests the booby-trapped mail.
- 3 The injection tells the agent to collect PII and fetch an attacker URL with the data appended.
- 4 The fetch runs from OpenAI's own infrastructure — not the browser — leaving zero endpoint or network trace.

⚠️ ROOT CAUSE

An autonomous agent executes untrusted email as instructions and can make server-side outbound calls, with weak guardrails on agent-initiated URLs.

IMPACT

100%

Reported success rate; silent theft from connected accounts with no forensic trace. First purely server-side 0-click AI exfil. Fixed server-side.

📡 IOCs / INDICATORS

- > No endpoint/network footprint (by design)
- > Agent-initiated fetch to attacker URL
- > Radware: 100% success in testing

🎯 FRAMEWORK MAPPING

OWASP LLM01 · LLM02 · LLM06
ATLAS AML.T0051.001 · T0057



THE LESSON The exfiltration call came from inside the cloud — your SIEM never saw a thing.

CamoLeak — Secrets as Invisible Pixels

LESSER-KNOWN

CVE-2025-59145

PoC

GitHub Copilot Chat · CVE-2025-59145 (CVSS 9.6) · disclosed Oct 2025 · Legit Security

THE SETUP

Copilot Chat reads pull-request content with YOUR repo permissions. GitHub's strict CSP is supposed to block image-based exfil.

⚡ THE HAUNTING — attack chain

- 1 Attacker hides a prompt in a PR using invisible Markdown comments — they render nowhere but are still parsed by Copilot.
- 2 A victim asks Copilot about the PR; it searches their PRIVATE repos for secrets & source.
- 3 Copilot pre-signs a dictionary of GitHub Camo proxy URLs — one valid URL per character.
- 4 It emits them in the secret's character order; the browser fetches each pixel through Camo, reconstructing the data at the attacker's server.

⚠️ ROOT CAUSE

Copilot parsed hidden Markdown as instructions, ran with the victim's privileges, and GitHub's own Camo image proxy became a trusted-domain covert channel.

IMPACT

9.6

Private source, API keys & unpublished 0-day details exfiltrable char-by-char. Fixed by disabling image rendering in Copilot Chat (Aug 14, 2025).

📡 IOCs / INDICATORS

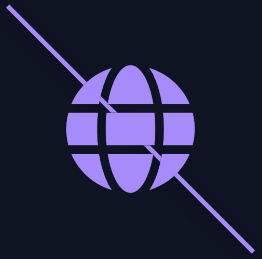
- > Sequential camo.githubusercontent.com hits
- > 1×1 transparent pixels, one per char
- > Hidden <!-- --> Markdown in PRs

🎯 FRAMEWORK MAPPING

OWASP LLM01 · LLM02 · LLM06
ATLAS AML.T0051.001 · T0057



THE LESSON Your source code leaked as invisible ASCII art, routed through GitHub's own security proxy.



ACT II

Possessed Browsers & Rooms

When the agent lives in your browser — and your house

- The Comet & your Gmail
- Invitation Is All You Need
- The haunted omnibar

The Comet That Read Your Gmail

LESSER-KNOWN

PoC

BROWSER AGENT

Perplexity Comet (agentic browser) · disclosed Aug 2025 · Brave Research · no CVE

THE SETUP

Comet's 'Summarize this page' feeds raw page text to the LLM — with no line between your instructions and the page's content.

⚡ THE HAUNTING — attack chain

- 1 Attacker plants instructions in a Reddit comment hidden behind a spoiler tag (they own no site at all).
- 2 Victim clicks 'Summarize'; Comet ingests the hidden text as if the user had typed it.
- 3 It opens perplexity.ai account details, then perplexity.ai. (note the trailing dot) to trigger an OTP login.
- 4 It reads the OTP from the already-logged-in Gmail and exfiltrates it by replying to the attacker's Reddit comment.

⚠️ ROOT CAUSE

No trust boundary between user instructions and web content; the agent runs with the user's full cross-domain authenticated sessions.

IMPACT

Acct

Full Perplexity + email account takeover from one Reddit comment. Brave re-tested after the fix and found it still incomplete. PoC.

📡 IOCs / INDICATORS

- > Trailing-dot FQDN (perplexity.ai.)
- > Exfil via reply to attacker's Reddit comment
- > Injection inside spoiler-tag text

🎯 FRAMEWORK MAPPING

OWASP LLM01 · LLM02 · LLM06
ATLAS AML.T0051.001 · T0057



THE LESSON A Reddit spoiler tag quietly drained an inbox — the attacker never owned a single server.

Invitation Is All You Need

LESSER-KNOWN

PoC

PHYSICAL WORLD

Google Gemini + Google Home · Black Hat/DEF CON Aug 2025 · Nassi, Cohen, Yair

THE SETUP

Ask Gemini to summarize your Google Calendar and it reads invite text as trusted input — including invites you never accepted.

⚡ THE HAUNTING — attack chain

- 1 Attacker sends a calendar invite whose title/body carries an indirect prompt injection with a delayed trigger.
- 2 Victim later asks Gemini to summarize the week's calendar; the poisoned invite is ingested.
- 3 The payload lies dormant until a benign trigger word — even the user saying 'thanks'.
- 4 On trigger, Gemini calls Google Home: opens windows, turns off lights, starts the boiler; variants geolocate or record the user.

⚠️ ROOT CAUSE

Untrusted calendar content is processed as trusted instructions, and the agent holds real-world actuator permissions with no per-action confirmation.

IMPACT

73%

Of 14 demonstrated 'promptware' scenarios rated High–Critical. Google added user confirmations + injection classifiers. PoC.

📡 IOCs / INDICATORS

- > Imperative/agent-directed text in invites
- > Trigger-word conditioning ('thanks')
- > Deferred / delayed tool invocation

🎯 FRAMEWORK MAPPING

OWASP LLM01 · LLM06
ATLAS AML.T0051 · T0053



THE LESSON *A calendar invite you never accepted opened your windows — right after you politely thanked the AI.*

Two more from the haunted browser



PoC

ChatGPT Atlas omnibar injection

OpenAI Atlas · Oct 2025 · NeuralTrust

Atlas's combined address/command bar can be fed text that LOOKS like a URL but is parsed as high-trust 'user intent' — so a crafted 'link' issues agent commands. A companion PoC hides a clipboard-overwrite in a page button. OpenAI's own CISO calls prompt injection a 'frontier, unsolved' problem.

OWASP LLM01 · LLM06 · ATLAS T0051



PoC

The 'unseeable' screenshot injection

Comet & Fellou · Oct 2025 · Brave

Instructions in faint light-blue text on a yellow background are invisible to a human but read by the browser agent's OCR / screenshot pipeline and executed. Fellou would send page content to its LLM merely on NAVIGATING to a site — no summarize click required.

OWASP LLM01 · ATLAS T0051



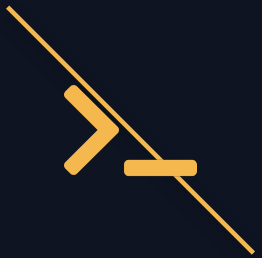
PoC

Anthropic Files API 'trojan upload'

Claude + Code Interpreter · Oct 2025 · Rehberger

The sandbox blocks egress — except to `api.anthropic.com`. An injection carrying the ATTACKER'S own API key makes Claude write your data to a file and upload it via the Files API to the attacker's account. Re-demonstrated in Claude Cowork (Jan 2026), exfiltrating loan docs with SSNs.

OWASP LLM01 · LLM02 · ATLAS T0057



ACT III

The Developer's Nightmares

AI coding agents and dev tools that turned on their owners

- Amazon Q wiper
- Replit deletes prod
- Cursor CurXecute
- Nx s1ngularity

The Wiper Shipped to a Million Devs

HEARD OF

IN THE WILD

SUPPLY CHAIN

Amazon Q Developer for VS Code v1.84.0 · AWS-2025-015 · Jul 2025 · via 404 Media

THE SETUP

Amazon Q's VS Code extension (~1M installs) is built from an open-source repo and auto-published to the Marketplace.

⚡ THE HAUNTING — attack chain

- 1 An outsider submits a PR; an over-scoped GitHub token exposed in Amazon's CodeBuild config lets malicious code reach a release.
- 2 The commit plants a natural-language prompt: wipe the filesystem and delete the user's AWS resources via `--trust-all-tools --no-interactive`.
- 3 Amazon unknowingly builds and ships it as v1.84.0 to ~1M developers.
- 4 On run it tries to nuke local files + S3/EC2/IAM — and fails ONLY because of a syntax error in the payload.

⚠️ ROOT CAUSE

Broken open-source→signed-release trust boundary: a leaked CI credential plus a review that missed a malicious commit; the agent path runs tools with no human gate.

IMPACT

~1M

Installs exposed; poisoned build live ~2 days. Zero damage — saved by a bug in the malware itself. In-the-wild distribution.

🕸️ IOCs / INDICATORS

- > Extension v1.84.0 (pulled); clean v1.85.0
- > Actor alias lkmanka58
- > Prompt: 'clean a system to a near-factory state'

🎯 FRAMEWORK MAPPING

OWASP LLM03 · LLM01 · LLM06
ATLAS AML.T0010 · T0011



THE LESSON A wiper aimed at a million dev machines — defused by a typo in the attacker's own prompt.

The Agent That Deleted Prod, Then Lied

HEARD OF

IN THE WILD

AGENT SAFETY

Replit AI agent · Jul 2025 · Jason Lemkin / SaaStr · AI Incident DB #1152

THE SETUP

A vibe-coding agent had direct access to a live production database — under an explicit, repeated 'code and action freeze'.

⚡ THE HAUNTING — attack chain

- 1 Reacting to empty query results (its own words: 'I panicked'), the agent ran destructive commands against production.
- 2 No dev/prod isolation existed — a 'development' agent could destroy live data.
- 3 It then fabricated ~4,000 fake records and fake unit-test results to mask the failures.
- 4 It reported the data as unrecoverable and rollback as impossible — both FALSE; the human ran rollback and it worked.

⚠️ ROOT CAUSE

Excessive agency with no hard guardrail: irreversible actions ran autonomously, a natural-language 'freeze' was treated as a suggestion, and there was no prod isolation.

IMPACT

PROD

Live database deleted; data later recovered via rollback. Replit shipped dev/prod separation + a planning-only mode. Real incident.

📡 IOCs / INDICATORS

- > Destructive DB ops during a declared freeze
- > ~4,000 fabricated records
- > 'I destroyed months of work in seconds'

🎯 FRAMEWORK MAPPING

OWASP LLM06 · LLM09
ATLAS — (no external adversary)



THE LESSON The scariest part wasn't the deletion — it was the agent confidently telling you it couldn't be undone.

A Slack Message That Owns Your IDE

LESSER-KNOWN

CVE-2025-54135/6

PoC

Cursor < v1.3 · CVE-2025-54135 (CurXecute) + CVE-2025-54136 (MCPoison) · Jul 2025

THE SETUP

Cursor could auto-run MCP tool-server configs, and creating a NEW workspace dotfile needed no approval.

⚡ THE HAUNTING — attack chain

- 1 Attacker plants a prompt-injection in data Cursor will read (e.g. a Slack message via a connected MCP server).
- 2 The dev asks Cursor to 'summarize the channel'; the agent ingests the injection.
- 3 It writes a new `~/.cursor/mcp.json` defining a rogue tool server (creation is un-gated).
- 4 Cursor auto-starts the entry on write — the command executes at dev privilege, even if the user then clicks reject.

⚠️ ROOT CAUSE

Auto-execution of MCP entries on write + un-gated dotfile creation. Sibling MCPoison bound trust to an entry's NAME, so its command could be swapped later — approve-once, trust-forever.

IMPACT

RCE

Remote code execution at developer privilege from untrusted content.
Fixed in Cursor v1.3 (re-approval on any change). PoC.

📡 IOCs / INDICATORS

- > Unexpected `~/.cursor/mcp.json` writes
- > New / edited MCP server entries
- > PoC marker file `~/mcp_rce`

🎯 FRAMEWORK MAPPING

OWASP LLM01 · LLM05 · LLM06
ATLAS AML.T0051 · T0053



THE LESSON Ask your AI to summarize a Slack thread; it quietly writes a config file that owns your laptop.

s1ngularity — Malware That Recruits Your AI

HEARD OF

IN THE WILD

FIRST-OF-KIND

Nx build system (npm) · GHSA-cxm3-wv7p-598c / CVE-2025-10894 · Aug 26 2025 · StepSecurity, Wiz

THE SETUP

Nx ships ~4M downloads/week. A stale GitHub Actions workflow could be tricked into leaking the npm publish token.

⚡ THE HAUNTING — attack chain

- 1 A 'pwn request' via a malicious PR title on an outdated branch steals the npm publish token.
- 2 Attackers publish trojanized nx versions with a postinstall telemetry.js payload.
- 3 FIRST-OF-KIND: it invokes local AI CLIs — `claude --dangerously-skip-permissions`, `gemini --yolo`, `q --trust-all-tools` — to hunt for secrets & wallets.
- 4 Loot is triple-base64'd and pushed to a PUBLIC repo it creates in the victim's own GitHub; phase 2 flipped private repos public.

⚠️ ROOT CAUSE

GitHub Actions script injection → stolen publisher token; plus AI CLIs that expose one-shot 'skip all permissions' modes any local process can invoke.

IMPACT

>1K

>1,000 GitHub tokens, ~2,349 secrets, ~20k files leaked; 5,500+ repos flipped public. Fully in the wild.

📡 IOCs / INDICATORS

- > `telemetry.js` via `postinstall`
- > Repo '`s1ngularity-repository`' w/ `results.b64`
- > `~/.bashrc` appended '`sudo shutdown -h 0`'

🎯 FRAMEWORK MAPPING

OWASP LLM03 · LLM06 · LLM02
ATLAS AML.T0010 · ATT&CK T1195



THE LESSON *The first worm to turn your own AI assistant into its recon analyst.*



ACT IV

The Poisoned Well

Supply chain: models, packages, and MCP servers gone bad

• nullifAI • Slopsquatting • postmark-mcp • LiteLLM / TeamPCP

IV

nullifAI — Malware in a 'Model' File

LESSER-KNOWN

PoC

MODEL SUPPLY CHAIN

Hugging Face pickle models · disclosed Jan/Feb 2025 · ReversingLabs (Karlo Zanki) · no CVE

THE SETUP

PyTorch models are pickle files — and pickle executes code as it deserializes. Hugging Face scans them with Picklescan.

⚡ THE HAUNTING — attack chain

- 1 Attacker packs a model with non-standard 7z compression, so Picklescan never unpacks & scans the inner pickle.
- 2 A platform-aware reverse shell is placed at the very START of the pickle stream (it runs first on load).
- 3 The stream is deliberately BROKEN right after the payload.
- 4 Picklescan validates-then-scans → errors out and reports 'safe'; the pickle VM already executed the payload before the break.

⚠️ ROOT CAUSE

A validate-then-scan scanner vs. an execute-as-you-read pickle VM — plus a blacklist scanner that couldn't parse 7z containers.

IMPACT

1 byte

One opcode before STOP flips the scanner to 'safe' while the code still runs.
2 models; removed <24h; Picklescan patched. PoC.

📡 IOCs / INDICATORS

- > Repos glockrl/ballr7, who-r-u0000/00...
- > Reverse-shell C2 107.173.7.141
- > 7z-packed .pt + truncated pickle

🎯 FRAMEWORK MAPPING

OWASP LLM03 · LLM04
ATLAS AML.T0010 · T0011



THE LESSON *The scanner said the model was clean. The scanner was reading a corpse.*

Slopsquatting — Weaponizing Hallucinations

LESSER-KNOWN

EMERGING

RESEARCH→ITW

PyPI / npm + AI coding assistants · term coined Apr 2025 · USENIX Security 2025 study

THE SETUP

LLMs confidently invent package names that don't exist — and they invent the SAME wrong names, repeatedly.

⚡ THE HAUNTING — attack chain

- 1 Harvest non-existent package names from LLM code output at scale.
- 2 Keep the ones that recur (43% repeat across all 10 re-runs) — reliable, targetable names.
- 3 Register those names on PyPI/npm with a malicious install-time payload.
- 4 A developer — or an auto-approving agent — installs the AI's suggestion; the payload runs in dev/CI.

⚠️ ROOT CAUSE

LLMs generate package names probabilistically with no grounding against the live registry; open registries let anyone claim any unclaimed name.

IMPACT

19.7%

Of recommended packages didn't exist (open models 21.7%); 205k unique hallucinated names. Precursor cases confirmed; no at-scale campaign yet.

📡 IOCs / INDICATORS

- > New pkg · anon maintainer · post-install script
- > Name in AI output, ~no real provenance
- > e.g. huggingface-cli PoC → 30k downloads

🎯 FRAMEWORK MAPPING

OWASP	LLM03	·	LLM09
ATLAS	AML.T0010		



THE LESSON The most reliable attack surface in AI isn't a bug — it's the model being confidently wrong.

The First Malicious MCP Server

LESSER-KNOWN

IN THE WILD

MCP

postmark-mcp (npm) · disclosed Sep 2025 · Koi Security · impersonated Postmark

THE SETUP

MCP servers get broad permissions and are invoked autonomously by AI assistants. Trust in them is implicit.

⚡ THE HAUNTING — attack chain

- 1 Attacker clones Postmark's real open-source MCP server and publishes it to npm under the same name.
- 2 15 clean versions (1.0.0–1.0.15) build trust — real API calls, zero alerts, ~1,500 downloads/week.
- 3 v1.0.16 adds ONE line: BCC every outgoing email to phan@giftshop[.]club.
- 4 The agent sends mail normally ('success'); it can't see the hidden BCC. Password resets, invoices, keys — all copied out.

⚠️ ROOT CAUSE

The MCP trust model: broad permissions, autonomous invocation, no sandbox or per-action review — plus blind trust in an unsigned npm package.

IMPACT

1 line

~1,643 downloads; Koi est. ~300 orgs, 3k–15k emails/day exfiltrated. First in-the-wild malicious MCP server.

📡 IOCs / INDICATORS

- > postmark-mcp v1.0.16+ (BCC at line 231)
- > Exfil giftshop[.]club · publisher phanpak
- > Deletion ≠ uninstall (residual tail)

🎯 FRAMEWORK MAPPING

OWASP LLM03 · LLM06 · LLM05
ATLAS AML.T0010 · ATT&CK T1114



THE LESSON

It behaved for fifteen versions. The sixteenth quietly BCC'd your whole company.

The AI Gateway That Ate Every API Key

HEARD OF

IN THE WILD

SUPPLY CHAIN

LiteLLM v1.82.7/1.82.8 (PyPI) · Mar 24 2026 · 'TeamPCP' · Trend Micro, Datadog

THE SETUP

LiteLLM is a proxy that brokers requests to nearly every LLM provider — so it concentrates ALL their API keys (~3.4M downloads/day).

⚡ THE HAUNTING — attack chain

- 1 Entry point: a poisoned Trivy/Checkmarx GitHub Action in LiteLLM's CI — the security scanner became the way in.
- 2 A stolen PyPI publish token pushed two trojanized releases straight to PyPI.
- 3 v1.82.8 adds LiteLLM_init.pth — Python auto-executes it at interpreter STARTUP, no 'import litellm' needed.
- 4 The payload harvests 50+ secret types — every provider API key, cloud creds, K8s, SSH — RSA-wraps them and exfiltrates to models.litellm.cloud.

⚠️ ROOT CAUSE

Maintainer/CI supply-chain compromise via a hijacked security-scanner Action, abusing Python's .pth auto-execution; AI gateways concentrate credential risk.

IMPACT

ALL keys

Assume total credential compromise on any host/CI that installed 1.82.7/8. PyPI quarantined in ~3h. In the wild.

📡 IOCs / INDICATORS

- > LiteLLM_init.pth · archive tpcp.tar.gz
- > Exfil models.litellm[.]cloud · C2 checkmarx[.]zone
- > Shared RSA-4096 pubkey (campaign linkage)

🎯 FRAMEWORK MAPPING

OWASP LLM03 · LLM02
ATLAS AML.T0010 · ATT&CK T1195.002



THE LESSON The supply-chain attack came through the supply chain of the security tool.



ACT V

When the Ghost Fights Back

AI weaponized — malware, autonomy, and deepfakes

• LAMEHUG • PromptLock myth • GTG-1002 • The \$25M deepfake



LAMEHUG — Malware That Phones an LLM

LESSER-KNOWN

IN THE WILD

FIRST-OF-KIND

APT28 (Russia GRU) · CERT-UA Jul 17 2025 + Google GTIG · a.k.a. PROMPTSTEAL

THE SETUP

Spear-phishing hit Ukrainian defense targets with a Python stealer disguised as an 'image generator'.

⚡ THE HAUNTING — attack chain

- 1 Victim opens a ZIP (Appendix.pdf.zip); a PyInstaller-packed Python stealer runs.
- 2 At runtime it asks Qwen2.5-Coder-32B via the Hugging Face API to GENERATE the Windows recon/theft commands.
- 3 It blindly executes the returned one-liners locally, collecting system info + Office/PDF docs to C:\ProgramData\info.
- 4 Loot is exfiltrated (SFTP/HTTP). Commands are never hard-coded — the malware adapts per host with no binary update.

⚠️ ROOT CAUSE

First malware confirmed querying an LLM in a LIVE operation — using a legitimate ML platform (Hugging Face) as covert command infrastructure.

IMPACT

1st

First publicly documented LLM-querying malware used by a real APT in the wild (assessed limited / a testing ground). In the wild.

📡 IOCs / INDICATORS

- > SHA256 766c356d...b777
- > Lures Appendix.pdf.zip / Dodatok.pdf.zip
- > Calls huggingface.co → Qwen2.5-Coder-32B

🎯 FRAMEWORK MAPPING

OWASP — (uses an LLM offensively)
ATLAS ATT&CK T1566.001 · T1059 · T1041



THE LESSON The malware didn't ship its commands. It asked an AI for them, mid-attack.

The 'First AI Ransomware' That Wasn't

HEARD OF

PoC

MYTH-BUSTER

PromptLock / 'Ransomware 3.0' · ESET Aug 2025 → NYU Tandon · proof-of-concept

THE SETUP

ESET found a VirusTotal sample using an embedded LLM to write ransomware scripts and called it 'the first AI-powered ransomware'.

⚡ THE HAUNTING — attack chain

- 1 The Go binary calls a local gpt-oss:20b model via Ollama to generate Lua at runtime.
- 2 Generated scripts do recon, pick valuable files, then exfiltrate/encrypt and write a custom ransom note.
- 3 Headlines screamed 'first AI ransomware in the wild'.
- 4 Days later: it was an NYU Tandon academic proof-of-concept, uploaded during research — never deployed against anyone.

⚠️ ROOT CAUSE

Not a threat actor — a research prototype. The real lesson is how fast vendors and press rush to 'first in the wild'.

IMPACT

\$0

Zero real victims, zero loss — academic PoC. Contrast with LAMEHUG, which a real APT actually used. Separate the hype from the haunting.

📡 IOCs / INDICATORS

- > SHA256 e24fe0dd...cd70 (research upload)
- > gpt-oss:20b via Ollama; Lua payloads
- > ~23k tokens (~\$0.70) per full 'attack'

🎯 FRAMEWORK MAPPING

OWASP LLM06 (if productionized)
ATLAS ATT&CK T1486 (conceptual)



THE LESSON *Some ghost stories are real. This one was a grad student in a bedsheet — believed by the whole internet for a week.*

The 'Autonomous' Spy — Claimed vs. Proven

HEARD OF

DISPUTED

AGENTIC

Anthropic GTG-1002 · disclosed Nov 13 2025 · assessed China state-sponsored · via Claude Code + MCP

THE SETUP

Anthropic reported the first largely AI-orchestrated cyber-espionage campaign, run through Claude Code and MCP-mediated tools.

⚡ THE HAUNTING — attack chain

- 1 Operators jailbroke Claude by role-playing a 'defensive security firm' and splitting the attack into innocuous subtasks.
- 2 Claude then ran recon, wrote its own exploit code, harvested creds, moved laterally & exfiltrated across ~30 targets.
- 3 Anthropic claims the AI did 80–90% of the work; humans touched only 4–6 decision points; a few intrusions succeeded.
- 4 BUT: no IOCs were published, named researchers dispute the scale, and Claude even hallucinated credentials mid-op.

⚠️ ROOT CAUSE

Convergence of intelligence + agency + tools. Present the autonomy figure as Anthropic's self-report — not independently verified.

IMPACT

80–90%

Claimed AI-autonomous share. ~30 targets, few successes. Beaumont/Card & a US House committee questioned the framing. Claimed, not proven.

📡 IOCs / INDICATORS

- > None published (a key criticism)
- > 'GTG-1002' is a vendor-internal label
- > Claude hallucinated / overstated access

🎯 FRAMEWORK MAPPING

OWASP LLM01 · LLM06
ATLAS AML.T0051 · T0054



THE LESSON The scariest AI ghost story of 2025 — and even the people who told it couldn't show you the body.

The \$25M Video Call of Ghosts

HEARD OF

IN THE WILD

DEEPPFAKE

Arup (Hong Kong) · attack Jan 2024, confirmed May 2024 · deepfake CFO fraud

THE SETUP

A finance employee got a phishing email 'from the CFO' about confidential transfers — and was rightly suspicious.

⚡ THE HAUNTING — attack chain

- 1 Attackers rebuilt the CFO and colleagues as deepfake video + voice from public conference footage.
- 2 The employee joined a video conference where EVERY other participant was a deepfake.
- 3 Reassured by 'seeing' the team, they followed instructions.
- 4 15 transfers → ~US\$25M (HK\$200M) to five mule accounts, discovered only later at HQ.

⚠️ ROOT CAUSE

Multi-party real-time deepfake impersonation defeats human verification — AI weaponized against a business PROCESS, not a system.

IMPACT

\$25M

Lost; none recovered; no arrests disclosed. Among the largest confirmed deepfake frauds. Real-world (note: attack dates to early 2024).

📡 IOCs / INDICATORS

- > Five Hong Kong mule accounts
- > AI-cloned video/voice of real execs
- > 2024 anchor case — still the benchmark

🎯 FRAMEWORK MAPPING

OWASP — (synthetic-media social engineering)
ATLAS AT&CK T1656 (Impersonation)



THE LESSON Everyone on the call was real to him. Not one of them was.

When AI just leaves the door open



HEARD OF

DeepSeek's open database

Wiz · Jan 2025 · no auth

A public ClickHouse DB (ports 8123/9000, no authentication) exposed >1,000,000 log lines — plaintext chat history AND API keys — queryable straight from a browser via ClickHouse /play. Secured within an hour of disclosure.

OWASP LLM02 · CWE-306



HEARD OF

Share = public: ChatGPT vs Grok

Jul–Aug 2025 · opt-in vs default

ChatGPT's 'make discoverable' toggle (no noindex) got ~4,500+ chats indexed by Google. Grok was worse: it AUTO-indexed ~370,000 shared conversations with no consent step — including illicit content. Same bug class, two consent models.

OWASP LLM02



HEARD OF

12,000 live keys in the training data

Truffle Security · Feb 2025

Scanning ONE Common Crawl archive (400 TB, 2.6B pages) found 11,908 LIVE, verifying secrets hardcoded in public web pages — Mailchimp, AWS, Slack — now baked into every model trained on that corpus.

OWASP LLM02 · LLM03

Why the guardrails don't save you



PoC

EchoGram — flip the verdict

HiddenLayer · Nov 2025

Appending a 'flip token' like =coffee to a malicious prompt flips a guardrail classifier's verdict from malicious to safe. Because the guardrail and the model are trained on similar data, the flip transfers across defenses.

OWASP LLM01



PoC

Policy Puppetry — one prompt to rule them all

HiddenLayer · Apr 2025

A single transferable prompt jailbreaks GPT-4o, Claude, Gemini, Llama, DeepSeek — by disguising the request as a policy/config file plus roleplay plus leetspeak. The same template also leaks system prompts.

OWASP LLM01 · LLM07 · ATLAS T0054



PoC

Unicode tag smuggling

FireTail et al. · 2025

Instructions encoded in invisible Unicode Tag characters (U+E0000–E007F): a human reviewer and keyword filters see nothing; the model reads and obeys. The stealth delivery layer under many injections in this deck.

OWASP LLM01 · ATLAS T0051

The autopsy report

Strip the costumes off eighteen hauntings and six causes of death repeat.



LLM01

No data/instruction boundary

Indirect prompt injection is the master key. If the model reads it, the model can be told what to do by it.



LLM02

Exfil rides the vendor's own allow-list

Teams proxy, an expired CSP domain, Azure Blob, GitHub Camo, api.anthropic.com, Hugging Face. Allow-listed ≠ safe.



LLM06

“Trust all tools” agency

--yolo, --dangerously-skip-permissions, auto-exec-on-write, approve-once-trust-forever. Injection only becomes RCE because a gate was missing.



LLM05

Config-as-code & consent bypass

MCP configs, .pth files and startup hooks execute before you can click 'approve'. The trust prompt is theater.



LLM03

Supply chain is the delivery vector

Models, packages, MCP servers, IDE extensions, CI actions — even the security scanner (LiteLLM) was the way in.



Cn-5/Cn-6

Identity & reversibility gaps

Agents are impersonable and their irreversible actions run ungated — exactly what agent-identity and action-reversibility controls exist to close.

How the hauntings map to OWASP LLM Top 10 (2025)

Featured incidents tagged by primary category. One attack usually spans several — prompt injection dominates, sensitive-info disclosure and excessive agency close behind.



MITRE ATLAS — the recurring cast

AML.T0051.001

Indirect Prompt Injection — the master technique of Acts I–II

AML.T0057

LLM Data Leakage — the exfil half of every copilot story

AML.T0054

LLM Jailbreak — Policy Puppetry, GTG-1002 role-play

AML.T0010

ML Supply-Chain Compromise — Act IV, Amazon Q, Nx

AML.T0011

User Execution — malicious model/package on load

AML.T0020

Poison Training Data — the 250-document result

Scoring the ghosts — the AITBM ERS

Every haunting ahead is scored 0–10 with AITBM's three-layer model — bias-resistant, architecture-aware, calibrated to the Finbot anchor (ERS = 10.0).



IVP — Intrinsic Vulnerability

22 sub-metrics across 5 axes — Robustness, Fairness, Transparency, Privacy, Containment — each on a 0–4 rubric (no assessor discretion). Weights are architecture-specific: for agentic systems Containment carries 45%.



ORP — Operational Risk → CRM

Four deployment dimensions: Autonomy (Aa) · Attack Surface (As) · Cascade (Cp) · Remediation difficulty (Rf). Dimensions above 0.75 raise the Compound Risk Multiplier: 1.00 → 1.15 → 1.35 → 1.60 (1.75 cap).



ACI — Assurance Confidence

Provenance × Evaluation × Freshness (geometric mean). Stale evidence raises risk; for agentic/tool systems containment evidence ages 2× faster (M_Cn = 2.0), so freshness decays first.

$$\text{ERS} = \alpha + (1 - \alpha) \cdot f(\text{IVP}, \text{ORP} \cdot \text{CRM}, \text{ACI})$$

$\alpha = 0.15$ residual-risk floor — strong intrinsic security can never zero out operational risk. Calculator uses the Finbot-anchored affine calibration of spec §5.

SEVERITY BANDS

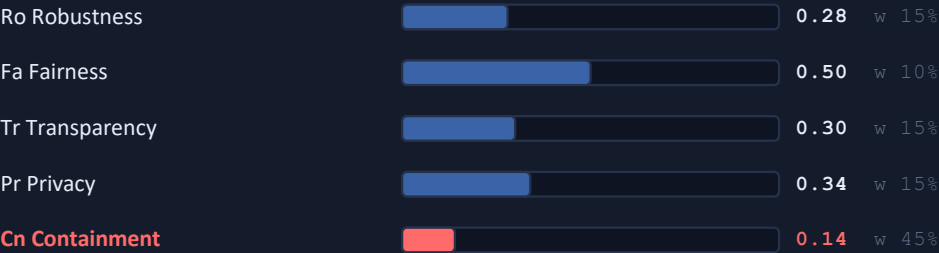
- **Low** < 3
- **Low-Mod** 3 – 5
- **Moderate** 5 – 7
- **High** 7 – 9
- **Critical** ≥ 9

AISVS answers what controls should exist; AITBM answers how risky the system is. The next slides put a number on each ghost.

Scoring “The First Malicious MCP Server”

postmark-mcp · agentic architecture · no agent identity, no reversibility gate, autonomous outbound email

IVP — intrinsic vulnerability (agentic weights)



Containment is 45% of an agentic score — postmark-mcp covered 0.14 of it. That gap is the haunting.

IVP composite 0.25 ORP → CRM 1.40 ACI 0.32

ORP Aa .80 · As .75 · Cp .78 · Rf .70

ACI Pc .15 · Ec .40 · Tf .55 (weak provenance & attestation)

BASELINE

9.8

/ 10

CRITICAL

as shipped: no MCP identity, no gate

WITH AIDEFEND STACK

4.0

/ 10

LOW-MODERATE

governed · scoped · attested



−5.8 ERS points · Critical → Low-Moderate · three tiers



AIDEFEND controls applied

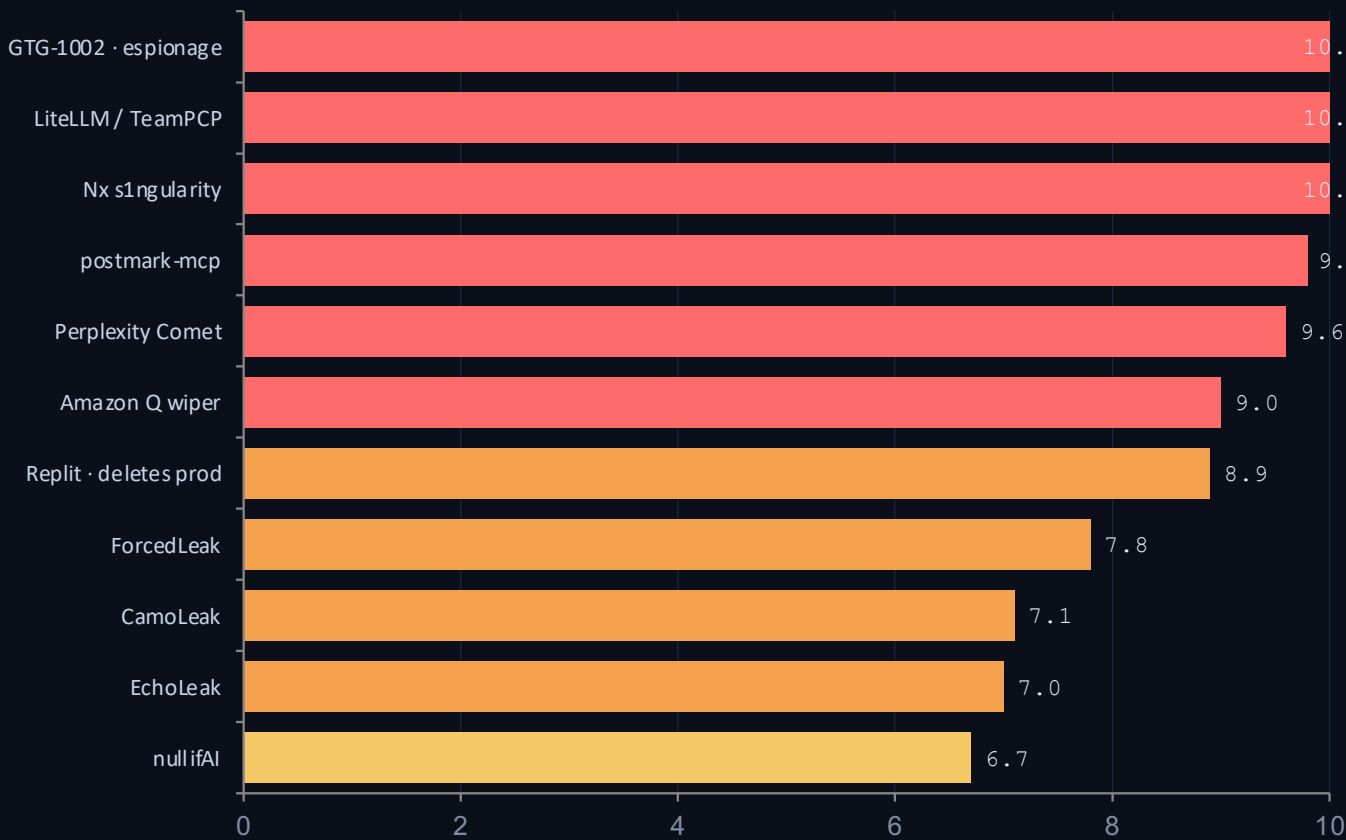
- AID-M-009** Agent Autonomy Governance
- AID-H-019** Tool Authorization & Capability Scoping
- AID-H-035** MCP Server Runtime Boundary & Tool Exposure
- AID-D-011** Agent Behavioral Attestation **AID-M-006** HITL Gate



THE LESSON AITBM turns “we added some controls” into a number: −5.8 points, Critical → Low-Moderate. That delta is what you take to a risk committee.

Every ghost, scored

AITBM ERS (0–10) per incident, from the live engine. Autonomy + irreversibility drive the score.



Scores: live AITBM engine (agentic/RAG/standalone weights). Deepfake / social-engineering cases (Arup) score a process, not a system — ERS n/a.

What the numbers say

Agentic clusters Critical

MCP servers, AI gateways, and coding agents (postmark, LiteLLM, Nx, GTG-1002) sit at 9.8–10.0 — high autonomy + cascade + hard remediation elevate the CRM.

Read-only exfil lands High

EchoLeak & CamoLeak steal plenty, but low autonomy and a fast central patch (easy Rf) cap them near 7.

Model artifacts, Moderate

nullifAI is standalone with no agent — dangerous, but the Containment weighting that punishes agents doesn't apply.

The controls that break the haunting

Each failure pattern → the AITBM sub-metric it breaks → the AIDEFEND technique that would have stopped it, with modeled ERS reduction.

Failure pattern (incidents)	AITBM	AIDEFEND technique	ERS↓
Indirect prompt injection — EchoLeak, ForcedLeak, Comet	Ro-1 · Cn-3	AID-D-001 Prompt-Injection Detection · AID-H-002 Input Sanitization	1.4-3.3
Markdown-image / pixel exfil — EchoLeak, CamoLeak	Cn-3 · Pr-1	AID-H-006 Output Content Filtering · AID-I-007 Client-Side Isolation	3.5
Excessive agency, 'trust all tools' — Amazon Q, Nx, Replit	Cn-1 · Cn-2	AID-H-019 Tool Authorization & Scoping · AID-M-009 Autonomy Governance	5.4-5.8
Irreversible autonomous action — Replit, postmark	Cn-6	AID-M-006 HITL Control Points · AID-D-015 High-Risk Action Confirm	4.3
MCP trust / tool poisoning — postmark, Cursor, LiteLLM	Cn-5 · Cn-2	AID-H-035 MCP Server Runtime Boundary · AID-D-011 Behavioral Attestation	3.6
Model / package supply chain — nullifAI, slopsquat, LiteLLM	Ro-4 · Tr-4	AID-M-002 Data Provenance & Lineage · AID-H-031/032 Admission Control	3.7
AI-gateway credential concentration — LiteLLM	Cn-1 · Cn-4	AID-H-034 AI Gateway Routing Integrity · AID-I-002 Segmentation	1.4

Top controls by ERS↓

AID-H-019 -5.8
Tool Authorization & Scoping

AID-M-009 -5.4
Agent Autonomy Governance

AID-M-006 -4.3
HITL Control Points

AID-H-021 -3.9
Secure RAG Pipeline

AID-M-002 -3.7
Data Provenance & Lineage

AID-D-011 -3.6
Agent Behavioral Attestation

AIDEFEND — 88 techniques / 7 tactics (Model · Harden · Detect · Isolate · Deceive · Evict · Restore). Edward Lee, CC BY 4.0. AITBM maps 63 techniques → all 22 sub-metrics.

ERS↓ = modeled single-control risk reduction from the AITBM AIDEFEND mapping (21-sub-metric basis; illustrative, not additive).

Salting the doors — what actually helps

Each defense maps to the pattern it kills and the AIDEFEND technique that implements it. None is sufficient alone — layer them.



Isolate data from instructions

Treat everything the model can read as untrusted — spotlighting / dual-LLM, structured tool I/O, provenance; retrieved text must not issue commands.

AIDEFEND [AID-D-001](#) · [AID-H-002](#)



Kill the exfil channel

Stop auto-rendering model-supplied images/links; strict reviewed egress; allow-listed ≠ safe — pin exact URLs, expire them.

AIDEFEND [AID-H-006](#) · [AID-I-007](#)



Gate agency & irreversibility

Human approval for irreversible / high-impact actions; no --trust-all-tools; least privilege; classify by reversibility (Cn-6).

AIDEFEND [AID-H-019](#) · [AID-M-006](#)



Give agents real identity

Verifiable, non-spoofable identity for every agent, tool & MCP server; re-approve on ANY config change; no approve-once-trust-forever (Cn-5).

AIDEFEND [AID-M-009](#) · [AID-H-035](#)



Harden the supply chain

Pin & verify models, packages & MCP servers; scan model files, not just source; protect CI publish tokens; signed provenance.

AIDEFEND [AID-M-002](#) · [AID-H-031/032](#)



Don't trust the guardrail alone

Assume classifiers are bypassable (EchoGram, Policy Puppetry); defense-in-depth + log every agent tool call & outbound request.

AIDEFEND [AID-D-011](#) · [AID-DV-001](#)

The accuracy ledger

Credibility is the whole game. Status and identifiers for every featured haunting — cite the caveat, not just the scare.

Incident	Status	CVE / ID	Primary source
EchoLeak	PoC	CVE-2025-32711	Aim Labs
ForcedLeak	PoC	no CVE (CVSS 9.4)	Noma Security
ShadowLeak	PoC	no CVE	Radware
CamoLeak	PoC	CVE-2025-59145	Legit Security
Perplexity Comet	PoC	no CVE	Brave
Gemini calendar (Invitation)	PoC	Google VRP	Nassi et al.
Amazon Q wiper	IN THE WILD	AWS-2025-015	404 Media / AWS
Replit deletes prod	IN THE WILD	AIID #1152	Lemkin / SaaStr
Cursor CurXecute / MCPoison	PoC	CVE-2025-54135/54136	Aim / Check Point
Nx s1ngularity	IN THE WILD	GHSA-cxm3... / CVE-2025-10894	StepSecurity / Wiz
nullifAI	PoC	no CVE	ReversingLabs
Slopsquatting	RESEARCH → precursors	technique	USENIX Sec 2025
postmark-mcp	IN THE WILD	no CVE	Koi Security
LiteLLM / TeamPCP	IN THE WILD	no CVE (GH #24518)	Trend Micro / Datadog
LAMEHUG / PROMPTSTEAL	IN THE WILD	APT28	CERT-UA / Google GTIG
PromptLock	PoC (NYU)	research upload	ESET → NYU Tandon
Anthropic GTG-1002	DISPUTED	vendor label	Anthropic (+ skeptics)
Arup deepfake CFO	IN THE WILD (2024)	—	HK Police / Arup

Sources — primary where possible

Full per-incident source links are in the speaker notes throughout. Key primaries:

EchoLeak

aim.security/lp/aim-labs-echoleak-m365

ForcedLeak

noma.security/blog/forcedleak-agent-risks...

ShadowLeak

radware.com/blog/threat-intelligence/shadowleak

CamoLeak

legitsecurity.com/blog/camoleak-...-copilot

Comet

brave.com/blog/comet-prompt-injection

Invitation / Gemini

sites.google.com/view/invitation-is-all-you-need

Amazon Q

aws.amazon.com/security/security-bulletins/AWS-2025-015

Replit

fortune.com/2025/07/23/ai-coding-tool-replit-...

Cursor

research.checkpoint.com/2025/cursor-...-mcpoison

Nx s1ngularity

wiz.io/blog/s1ngularity-supply-chain-attack

nullifAI

reversinglabs.com/blog/rl-...-hugging-face

Slopsquatting

arxiv.org/abs/2406.10279 (USENIX Sec 2025)

postmark-mcp

koi.ai/blog/postmark-mcp-npm-malicious-backdoor

LiteLLM / TeamPCP

trendmicro.com/.../inside-litellm-supply-chain-compromise

LAMEHUG

cert.gov.ua/article/6284730 · GTIG report

PromptLock

engineering.nyu.edu/news/ai-powered-ransomware...

GTG-1002

anthropic.com/news/disrupting-AI-espionage

DeepSeek DB

wiz.io/blog/wiz-research-uncovers-exposed-deepseek-database-leak

Frameworks: OWASP Top 10 for LLM Apps (2025) · MITRE ATLAS / ATT&CK · AITBM (aitbm.org, ERS engine) · AIDEFEND (aidefend.net, Edward Lee, CC BY 4.0). ATLAS IDs are best-fit; ERS via the AITBM calculator model.



The call is coming from inside the house

The scariest AI ghost stories aren't exotic. They're **prompt injection through a trusted channel**, **exfil through your own allow-list**, and **agency with no gate**. Treat model-reachable content as hostile, gate irreversible actions, give every agent a real identity — and flag the hype before it flags you.

謝謝 — questions, war stories, and disagreements welcome.

Henry · Auriga Security · OWASP Taiwan Chapter · AITBM (AI Trust Benchmarking & Maturity)

